

Université Tahri Mohamed , Bechar
Faculté des Sciences Exactes

4ieme Année Ingénieur
Cyber Security

Cours : Cybersécurité

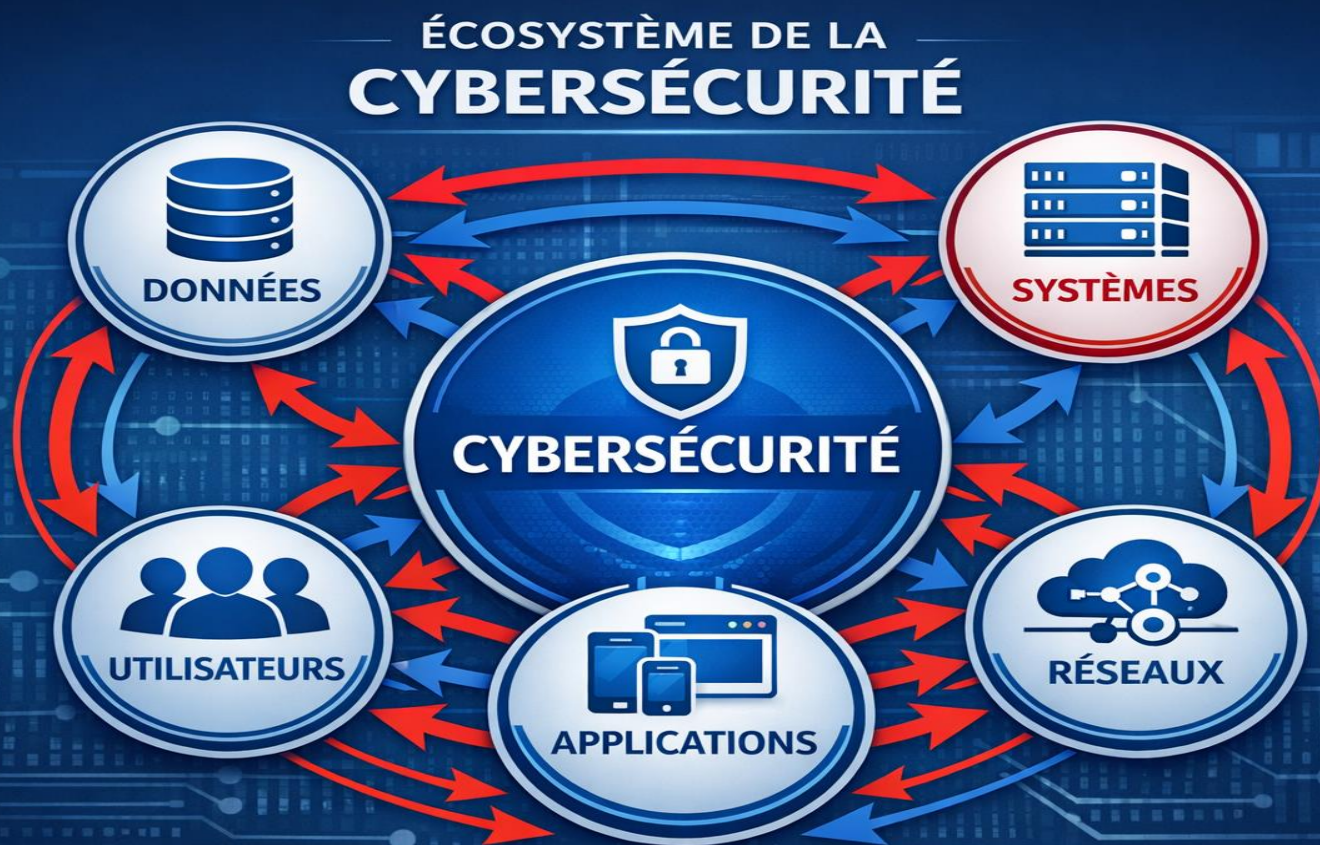
Chapitre I: Concepts Fondamentaux de la Cybersécurité

Code ClassRom : 3kvggzl5

Prof. BENAHMED Khelifa
2026

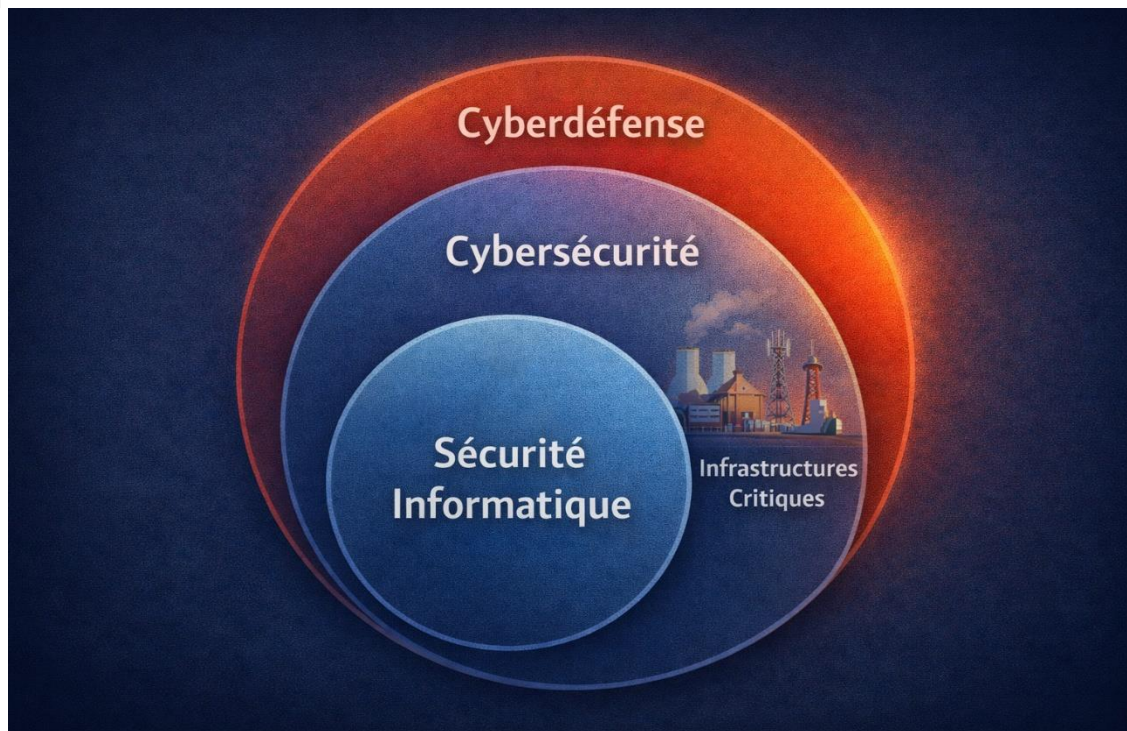
Définition de la Cybersécurité :

La cybersécurité est l'ensemble des technologies, processus, pratiques et mesures conçus pour protéger les réseaux, les appareils, les programmes et les données contre les attaques, les dommages ou les accès non autorisés.



Terminologie

- **Sécurité Informatique (IT Security)** : Plus centrée sur la protection de l'infrastructure informatique (serveurs, postes de travail, données).
- **Cybersécurité (Cybersecurity)** : Champ plus large qui inclut la sécurité des systèmes d'information dans leur environnement connecté (réseaux, Internet, objets connectés), ainsi que les aspects humains et organisationnels.
- **Cyberdéfense (Cyberdefense)** : Dimension proactive et étatique, souvent militaire, de protection des infrastructures critiques et de réponse aux agressions cybernétiques.



Objectifs de la Cybersécurité

Elle vise à assurer la **confidentialité**, l'**intégrité** et la **disponibilité** de l'information (Triade **CIA**).



Objectifs de la Cybersécurité

- **Authenticité** : Garantir que les données, les transactions et les communications proviennent bien de la source déclarée.
- **Non-Répudiation** : S'assurer qu'une partie prenante ne peut nier avoir effectué une action (ex: envoi d'un mail, signature d'un contrat numérique). L'utilisation de certificats et de signatures électroniques est centrale.
- **Responsabilité (Accountability)** : Pouvoir tracer les actions d'un utilisateur ou d'un système jusqu'à une entité responsable.(par les fichiers Logs).
- **Gestion du Risque Cyber** : Identifier, évaluer et prioriser les risques pour les traiter de manière économique et efficace.
- **Conformité (Compliance)** : Respecter les réglementations (RGPD, NIS 2, LPM, etc.) et les standards sectoriels (PCI-DSS pour le paiement, HIPAA pour la santé).
- **Continuité d'Activité et Reprise après Sinistre** : Garantir la résilience des activités face à un incident majeur.

RGPD (Règlement Général sur la Protection des Données)

La directive NIS 2 : renforce la cybersécurité des entités essentielles et importantes (énergie, santé, transport, numérique, etc.)

La Loi de Programmation Militaire (LPM) : impose des mesures de cybersécurité strictes aux opérateurs d'importance vitale. Elle renforce la protection des infrastructures critiques,

La norme **PCI DSS (Payment Card Industry Data Security Standard)** est un standard de sécurité mondial obligatoire pour toute entité stockant, traitant ou transmettant des données de cartes bancaires.

La loi **HIPAA** (Health Insurance Portability and Accountability Act) impose des normes strictes sur la confidentialité, la sécurité et la transmission des informations de santé protégées (PHI - *Protected Health Information*).

Importance de la Cybersécurité dans un Monde Numérique

Prendre conscience des enjeux économiques, sociaux et géopolitiques.

➤ Contexte Numérique

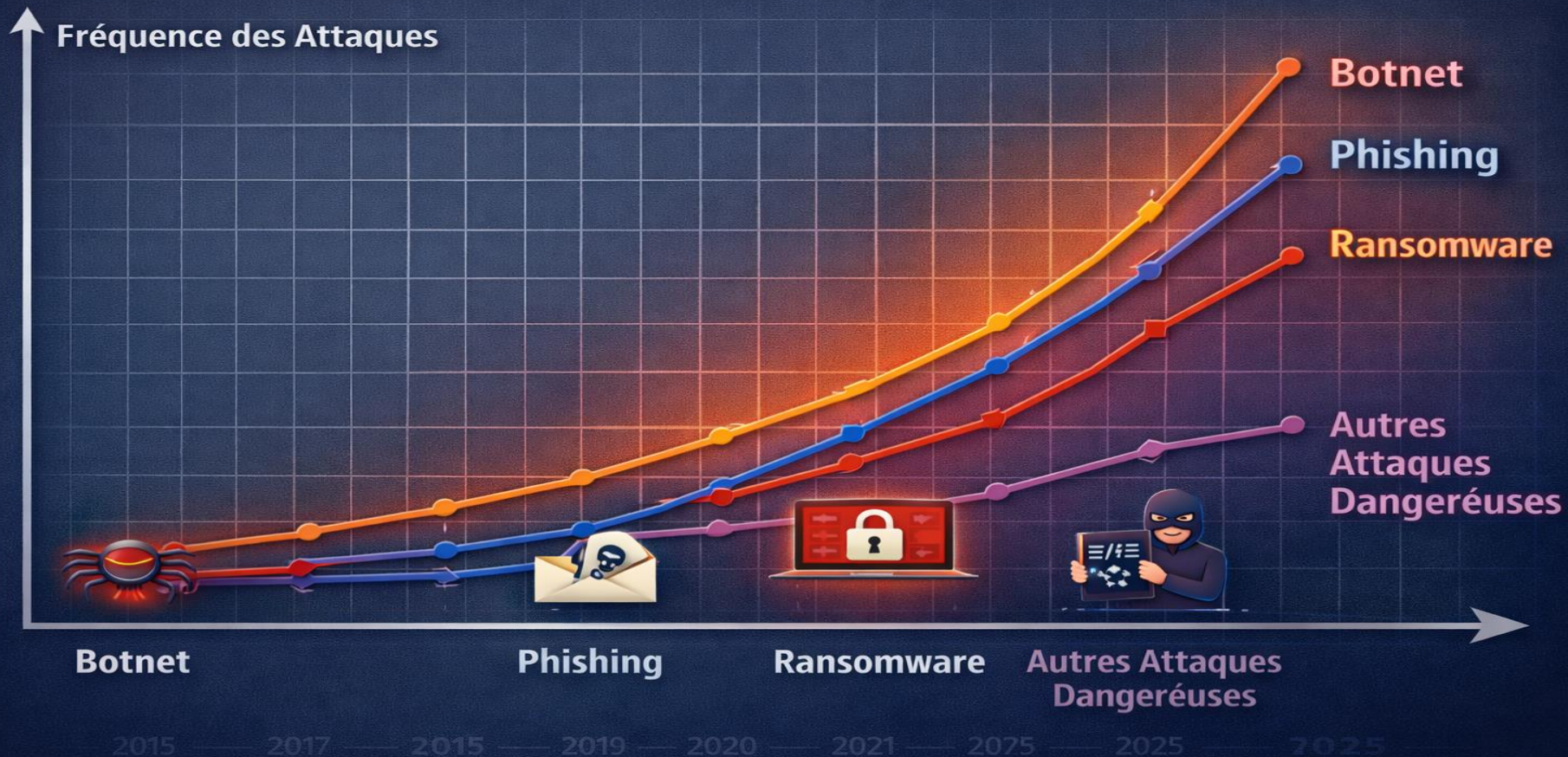
- **Hyper-Connexion** : Expansion de l'IoT (plus de 15 milliards d'appareils connectés), 5G, Cloud hybride, IA générative.
- **Impact Économique** : Le coût mondial de la cybercriminalité dépasser **10 500 milliards de dollars annuels en 2025** (rapport CyberSecurity Ventures 2023).
- **Les Menaces** :
 - **Ransomware (Chiffrement + Exfiltration)** : Menace numéro 1 pour les entreprises et les institutions. Ex: attaques contre des hôpitaux, des collectivités territoriales.
 - **Phishing** : (**Ingénierie sociale**, ...)
 - **Cyber-espionnage** : Menace ciblant la propriété intellectuelle et les données sensibles. (**Trojon**, **Pegasus**, ...),
 - Dos, Ddos : (**STAXNET**, **Flam** , ...)
 - **Désinformation et Ingérence** : Utilisation de bots, arnaques et de deepfakes pour influencer l'opinion, pendant les élections par exemple, etc.

- **Enjeux pour la Société**

- **Souveraineté Numérique** : Dépendance technologique et contrôle des données.
- **Protection des Citoyens** : Vie privée, protection des données personnelles, sécurité des objets connectés grand public (voitures, domotique).
- **Infrastructures Critiques** : Sécurité des secteurs de l'énergie, des transports, de la santé, de la finance (directive européenne NIS 2).

Évolution du paysage des menaces (2015-2025).

ÉVOLUTION PAR TYPE D'ATTAQUE CYBERNÉTIQUE (2015-2025)



MENACE INFORMATIQUE CARTE EN TEMPS RÉEL :

<https://cybermap.kaspersky.com/fr/stats#country=129&type=OAS&period=w>

Les Approches de la Cybersécurité

Partie 1 : Les Approches Fondamentales

Ces approches définissent les piliers techniques sur lesquels repose la sécurité.

1- Approche par la Défense en Profondeur (Defense-in-Depth)

Principe : Empiler plusieurs couches de défense (physique, réseau, hôte, application, données) pour qu'une défaillance à un niveau ne compromette pas l'ensemble du système.



Politiques & Sensibilisation

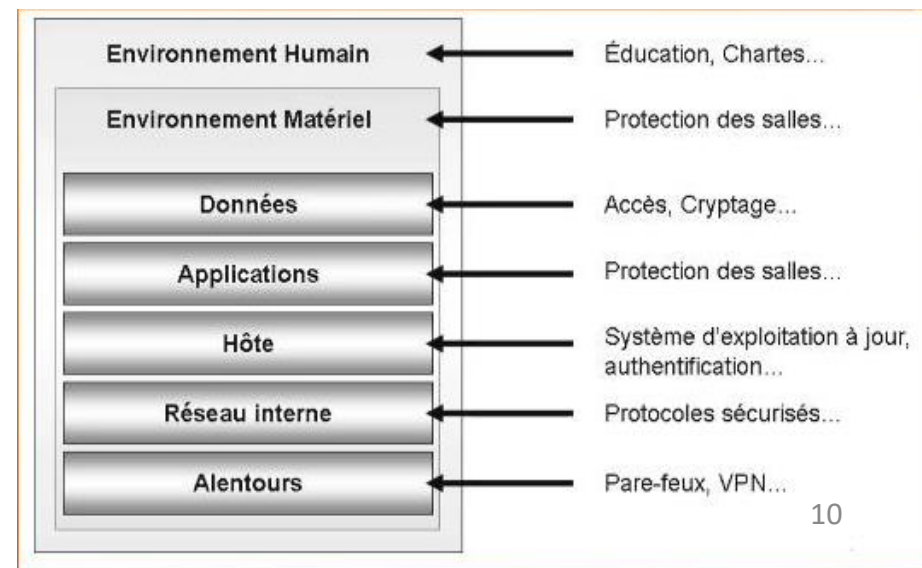
Périmètre Physique (Badges, Locaux)

Périmètre Réseau (Firewall, IDS/IPS, VPN)

Sécurité des Endpoints (EDR, Antivirus)

Sécurité des Applications (WAF)

Sécurité des Données (Chiffrement)



1- Approche par la Défense en Profondeur (Defense-in-Depth)

Les Couches (de l'externe vers l'interne) :

- **Politiques et Sensibilisation** : La base (règles, formation des employés).
- **Périmètre Physique** : Sécurité des locaux, badges.
- **Périmètre Réseau** : Firewalls, systèmes de détection d'intrusion (IDS/IPS), VPN.
- **Sécurité des Endpoints** : Antivirus, EDR (Endpoint Detection and Response) sur les postes de travail et serveurs.
- **Sécurité des Applications** : Pare-feu applicatifs (WAF), code sécurisé.
- **Sécurité des Données** : Chiffrement (au repos et en transit), contrôles d'accès stricts.

Objectif : Ralentir l'attaquant et augmenter la probabilité de le détecter avant qu'il n'atteigne sa cible finale.

2. L'Approche "Zero Trust" (Confiance Zéro)

- "Ne jamais faire confiance, le Zero Trust considère que le réseau est systématiquement hostile.

- **Trois Concepts :**

- **Micro-segmentation** : Découpage du réseau en zones très petites. Même si un attaquant pénètre une zone, il ne peut pas se déplacer latéralement vers les autres.
- **Accès au moindre privilège** : Un utilisateur ou une machine n'a accès qu'aux seules ressources nécessaires à sa tâche, et rien de plus.
- **Vérification continue** : La confiance n'est pas acquise pour toute une session. On vérifie en permanence l'identité et le contexte (heure, localisation, santé de l'appareil).

Mise en œuvre : Elle repose souvent sur des technologies comme l'authentification multi-facteurs (**MFA**), la gestion des identités (**IAM**) et le **chiffrement de bout en bout** (*End-to-end encryption, E2EE*).

Examples of Multi-Factor Authentication



1. Connaissances: C'est le facteur que les utilisateurs connaissent le plus, telles qu'un mot de passe, un numéro d'identification personnel (PIN), une clé de sécurité ou la réponse à une question de sécurité.

2. Possession: Ce facteur vérifie l'identité de l'utilisateur en utilisant quelque chose qu'il possède. Par exemple, en envoyant un code à un téléphone mobile.

3. Inhérence: Ce facteur vérifie la personne par un attribut personnel unique, tel que l'authentification biométrique ou la reconnaissance vocale.

La gestion des identités et des accès (IAM)

(IAM - *Identity and Access Management*) est composée de politiques et de technologies, qui garantit que seules les personnes autorisées accèdent aux ressources numériques.

Composants de l'IAM :

- **Authentification** : Vérification de l'identité de l'utilisateur (mots de passe, biométrie, authentification multifacteur - MFA).
- **Autorisation** : Définition des niveaux d'accès et des privilèges spécifiques (rôles).
- **Provisionnement** : Création, mise à jour et suppression des identités numériques au fil du cycle de vie de l'utilisateur.
- **Gestion des privilèges** : Surveillance et contrôle des accès à haut risque (administrateurs).
- **Audit et Reporting** : Suivi des accès pour la conformité réglementaire (RGPD: (Règlement Général sur la Protection des Données),, SOX: La loi Sarbanes-oxley). Traçabilité , ...



3. L'Approche "Risk-Based" (Basée sur les Risques)

Il est impossible de tout protéger contre tout. Il faut donc **prioriser les efforts de sécurité** en fonction des risques réels pour l'organisation.

. Processus :

1. **Identification des actifs** : Qu'a-t-on de précieux ? (Données clients, propriété intellectuelle, etc.).
2. **Évaluation des menaces** : Qui veut nous attaquer et comment ?
3. **Analyse des vulnérabilités** : Quelles sont nos failles ?
4. **Calcul du Risque** : $\text{Risque} = (\text{Probabilité qu'une menace exploite une vulnérabilité}) \times (\text{Impact sur l'organisation})$.
5. **Traitement** : On choisit de réduire, transférer (ex: assurance), éviter ou accepter le risque.

Avantage : Optimisation du budget de sécurité. On investit là où le risque est le plus critique.

Partie 2 : Les Approches par Cycle de Vie

Ces approches se concentrent sur la **temporalité de l'attaque**.

4. L'Approche "Proactive" (Proactive)



Empêcher l'attaque d'avoir lieu.

. Activités :

- **Gestion des correctifs (Patch Management)** : Mettre à jour les logiciels pour combler les failles connues.
- **Tests d'intrusion** : Simuler une attaque pour trouver les faiblesses avant les vrais pirates.
- **Sécurisation du code (DevSecOps: (Développement, Sécurité, Opérations))** : Intégrer la sécurité dès la conception des applications.
- **Chasse aux menaces (Threat Hunting)** : Chercher activement des signes de compromission dans le réseau, avant qu'une alerte ne se déclenche.

5. L'Approche Réactive

- Répondre efficacement une fois que l'attaque est en cours ou a réussi.
- **Activités :**
 - **Détection : Surveillance des logs**, alertes **SIEM** (Security Information and Event Management). **Détectez et identifiez les failles de sécurité et menaces potentielles en temps réel**, ce qui réduit le risque de compromission.
 - **Analyse forensique** : Comprendre comment l'attaque s'est produite et quels dégâts ont été causés.
 - **Contention (Containment)** : Isoler les machines infectées pour empêcher la propagation.
 - **Éradication et Rétablissement** : Nettoyer les systèmes et restaurer les données depuis les sauvegardes.

Exercice 1 : [07 pts]

Vous analysez le fichier **access.log** d'un serveur Apache après une suspicion d'intrusion.

Extrait du fichier access.log :

```
192.168.1.45 - - [15/Jan/2024:10:23:45 +0000] "GET /products.php?id=5 HTTP/1.1" 200 3421
```

```
192.168.1.45 - - [15/Jan/2024:10:24:12 +0000] "GET /products.php?id=5' HTTP/1.1" 200 3421
```

```
192.168.1.45 - - [15/Jan/2024:10:24:38 +0000] "GET /products.php?id=5' OR '1'='1 HTTP/1.1" 200 8954
```

```
192.168.1.45 - - [15/Jan/2024:10:25:01 +0000] "GET /products.php?id=5' UNION SELECT NULL,NULL,NULL-- HTTP/1.1" 200 2847
```

```
192.168.1.45 - - [15/Jan/2024:10:25:45 +0000] "GET /products.php?id=5' UNION SELECT username,password,email FROM users-- HTTP/1.1" 200 15632
```

1. Identifiez le type d'attaque
2. Quelle est la progression de l'attaquant ?
3. L'attaque a-t-elle réussi ?
4. Quelles informations ont potentiellement été compromises ? Quelles actions recommandées vous pour la protection ?

Exercice 1 - Correction : [07 pts]

1. Type d'attaque : Il s'agit d'une attaque par injection SQL classique. [01 pt]

2. Progression de l'attaquant : [2.5 pts]

Ligne 1 (10:23:45) : Requête légitime pour établir une connexion (Login)

Ligne 2 (10:24:12) : Test avec une apostrophe simple pour détecter une vulnérabilité SQL (code 200 = pas d'erreur visible)

Ligne 3 (10:24:38) : Injection basique OR '1'='1 pour contourner l'authentification. La taille de réponse passe à 8954 octets (contre 3421 initialement), indiquant que plus de données sont retournées

Ligne 4 (10:25:01) : Utilisation de UNION SELECT pour déterminer le nombre de colonnes (test avec 3 colonnes NULL)

Ligne 5 (10:25:45) : Extraction de données de la table users : username, password et email. La réponse de 15632 octets suggère une extraction massive

Exercice 1 - Correction la suite ...

3. Succès de l'attaque : OUI, l'attaque a réussi. Les codes HTTP 200 confirment que toutes les requêtes ont abouti sans erreur. L'augmentation progressive de la taille des réponses prouve que l'attaquant a réussi à extraire des données. [01 pt]

4. Informations compromises : [01.5 + 1 pts]

- Noms d'utilisateurs, Mots de passe (probablement hashés, mais potentiellement cassables), Adresses email , Structure de la base de données

- Actions recommandées :

- Bloquer immédiatement l'IP 192.168.1.45
- Forcer la réinitialisation de tous les mots de passe
- Corriger la vulnérabilité SQL (utiliser des requêtes préparées)
- Vérifier les autres tables pour d'éventuelles extractions supplémentaires

6. L'Approche Prédictive

- Anticiper la prochaine attaque grâce à **l'intelligence artificielle** et à l'analyse des tendances.
- **Méthodes :**
 - **Renseignements sur les menaces (Threat Intelligence)** : Collecter des données sur les tactiques des attaquants, les malwares émergents, les forums du dark web.
 - **Analyse comportementale (UEBA: L'analyse comportementale des utilisateurs et des entités)** : Utiliser le machine learning pour établir une base de référence du comportement normal des utilisateurs et machines, et détecter les écarts (ex: un employé qui télécharge 1To à 3h du matin).

References :

1- **Distributed monitoring for misbehaviour detection in wireless sensor networks.**

[Khelifa Benahmed, Madjid Merabti, Hafid Haffaf , 2012].

2- **Inspired social spider behavior for secure wireless sensor networks**

[K Benahmed, M Merabti, H Haffaf , 2012].

Partie 3 : Les Approches par Périmètre et Organisation

7. L'Approche "Cloud" (Shared Responsibility Model)

- **Principe** : La sécurité **DANS** le cloud vs. la sécurité **DU** cloud.
- **Modèle de Responsabilité Partagée** :
 - **Le Fournisseur (AWS, Azure, Google)** : Responsable de la sécurité **du** cloud (sécurité physique des datacenters, du matériel, du réseau , etc ...).
 - **Le Client** : Responsable de la sécurité **dans** le cloud (gestion des identités et accès, configuration des instances, sécurité des données, système d'exploitation).
 - *(Note : Le partage des responsabilités varie selon le type de service : IaaS, PaaS, SaaS).*

8. L'Approche "Industrielle" (Cybersécurité des OT - Operational Technology)

Protéger les systèmes qui contrôlent le monde physique (centrales électriques, chaînes de montage,).

- **Spécificités :**

- **Priorité à la Disponibilité et à la Sécurité Physique :** Contrairement à l'IT où la confidentialité des données est importante , dans l'industrie, il faut d'abord éviter l'arrêt de production ou l'accident.
- **Systèmes anciens (Legacy) :** Des machines fonctionnent avec des logiciels vieux de 20 ans, impossibles à patcher.
- **Le "Air Gap" :** Un *air gap* (ou « **coupure d'air** ») est une mesure de sécurité informatique consistant à isoler physiquement un ordinateur ou un réseau de tout réseau non sécurisé, y compris Internet. Cette déconnexion totale empêche les cyberattaques, ransomwares et accès non autorisés, assurant la protection des données ultra-critiques.

Partie 4 : Les Frameworks et Normes (Standardisation des Approches)

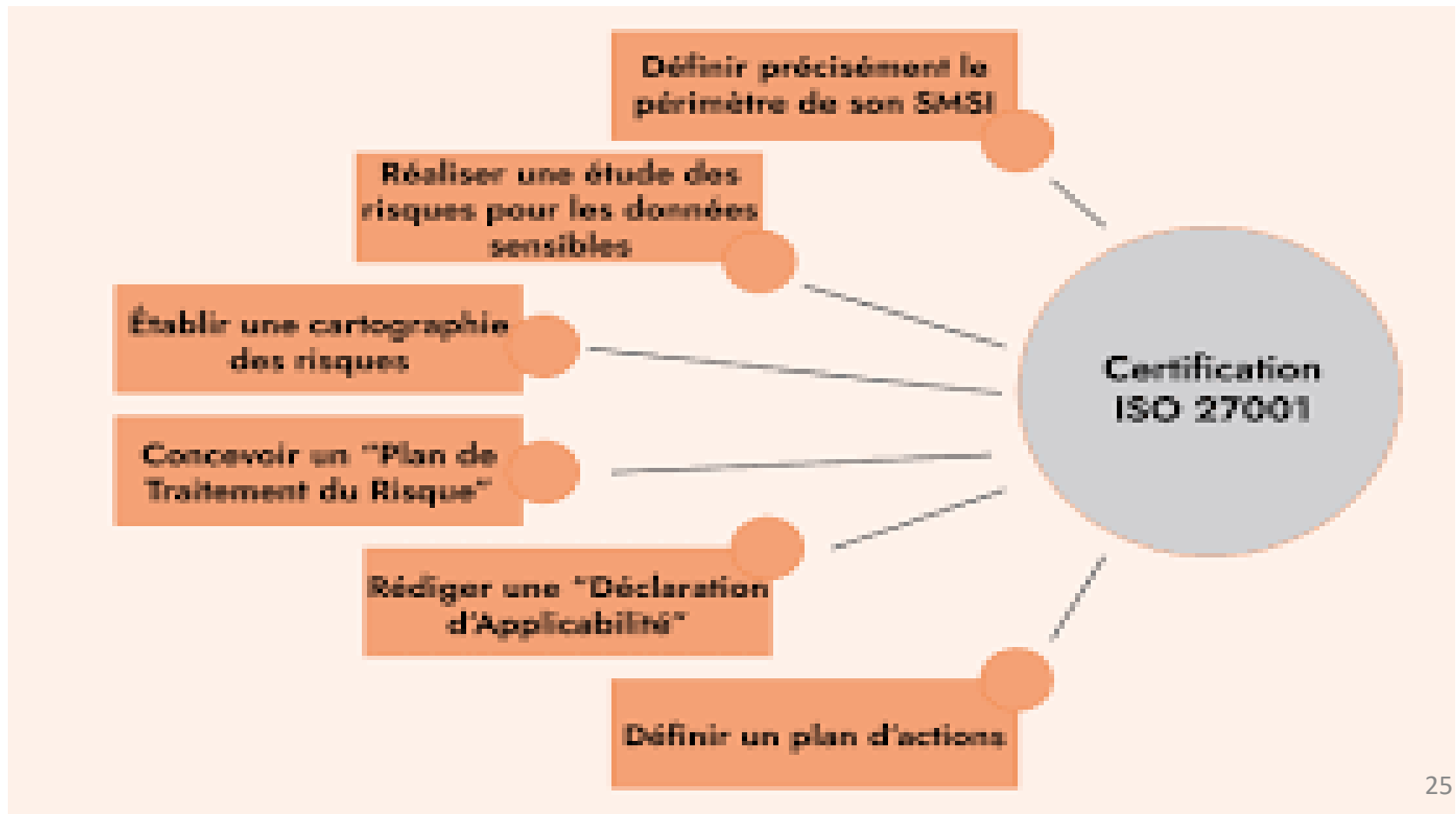
9. Le **Framework NIST** (National Institute of Standards and Technology)

C'est probablement le cadre le plus utilisé mondialement. Il propose **une approche cyclique basée sur 5 fonctions continues** :

1. **Identifier** : Comprendre le contexte, les actifs et les risques.
2. **Protéger** : Mettre en place les garanties nécessaires (contrôle d'accès, sensibilisation).
3. **Détecter** : Découvrir les incidents rapidement.
4. **Répondre** : Agir en cas d'incident.
5. **Récupérer** : Rétablir les capacités et services impactés.

10. La norme ISO 27001

- **Principe** : Mettre en place un Système de Management de la Sécurité de l'Information (SMSI). Elle couvre l'ensemble de l'organisation (personnes, processus, technologie) et permet d'obtenir une certification reconnue.



Choisir la bonne approche

Il n'y a pas de solution unique. Une stratégie de cybersécurité est **hybride** :

- On utilise la **défense en profondeur** pour l'architecture.
- On applique le **Zero Trust** pour les accès.
- On priorise avec une approche **basée sur les risques**.
- On suit le cycle du **NIST** pour la gestion continue.
- On adapte le tout au contexte (Cloud, Industriel, etc.).

L'évolution actuelle tend vers une approche de plus en plus **automatisée et prédictive**, où la sécurité devient un processus continu et intégré, plutôt qu'une série de contrôles ponctuels.